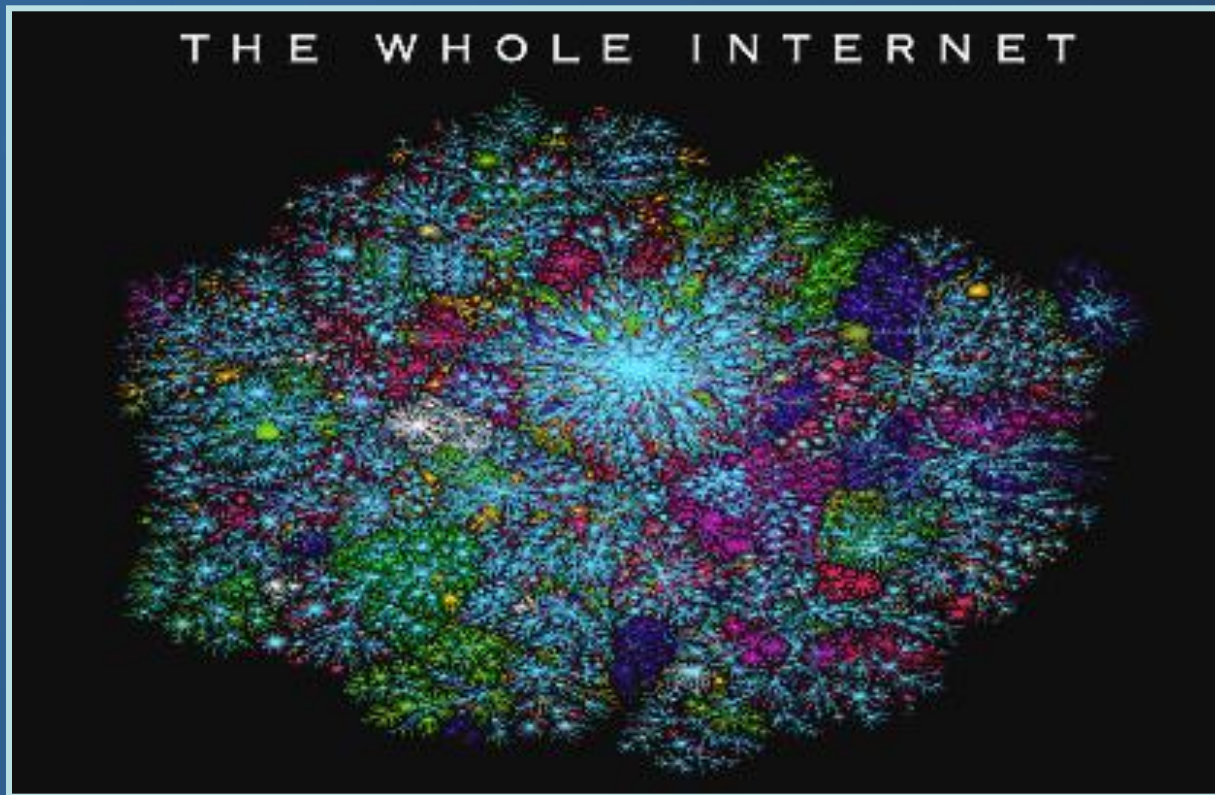


Network Security



Information Security and Privacy Office





We work with the Internet and networks every day

But we don't know what they are



Agenda

- Basic terminology
- OSI 7-Layer Model
 - Function, devices, protocols
- Network threats
- Network security safeguards



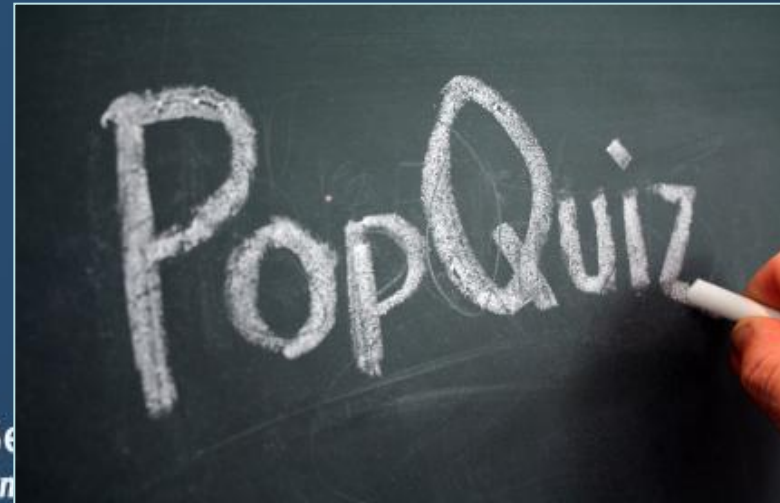
Quiz

- What is a basic security problem in distributed systems?
 - Knowing who to trust
 - Knowing the order of transactions
 - Knowing when to reconnect
 - Knowing how to name resources



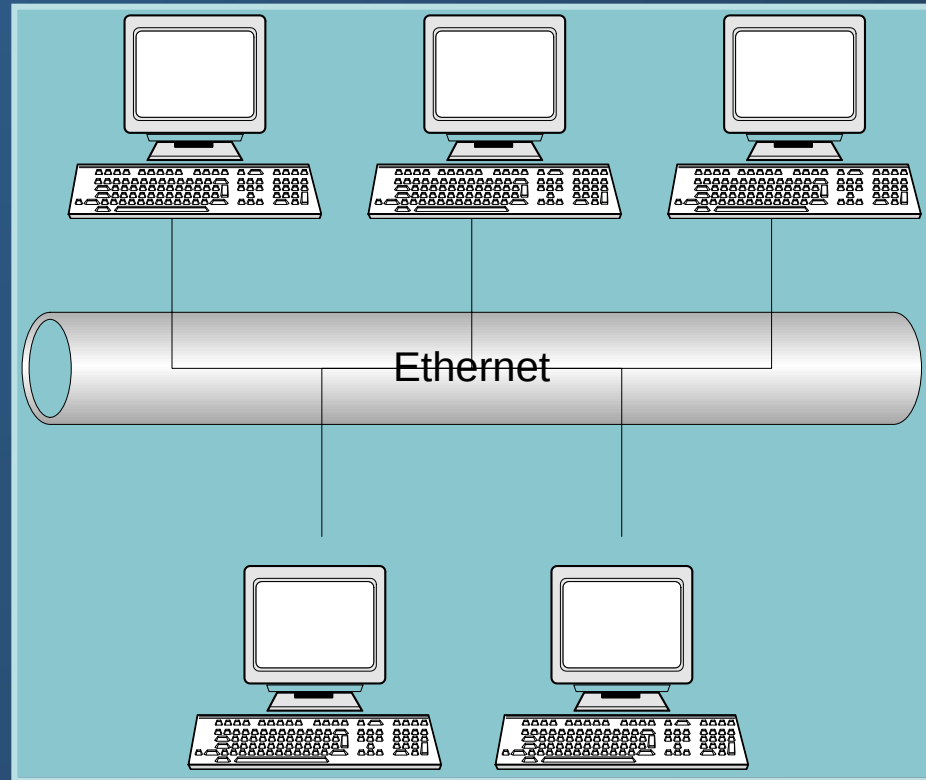
Quiz

- What is a basic security problem in distributed systems?
 - Knowing who to trust
 - Knowing the order of transactions
 - Knowing when to reconnect
 - Knowing how to name resources



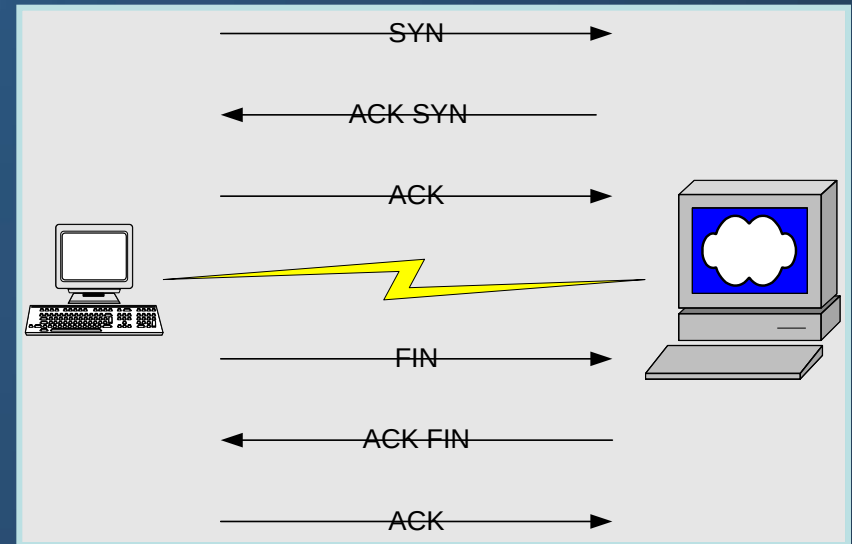
Networks – Overview

- Network – a collection of computers that can communicate with each other
- Local area network (LAN) – a group of computers and associated devices that share a common communications line within a small geographical area
- Wide area network (WAN) – a geographically dispersed network that is usually made up of smaller LANs



Protocol

- Protocol – an agreed-upon format for transmitting data between two devices
- Defines
 - How the sending device will indicate that it has finished sending a message
 - How the receiving device will indicate that it has received a message
 - How to make sure the message sent is the message received (error checking)

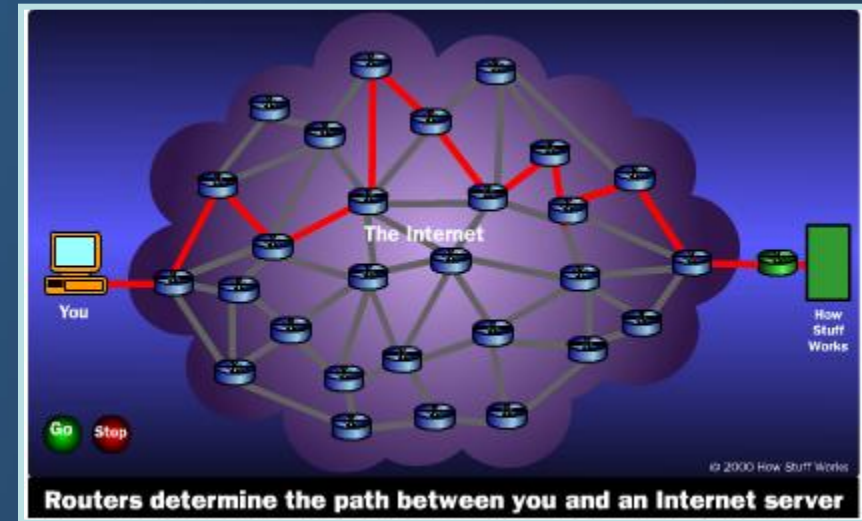


TCP 3-Way Handshake



The Internet

- Internet – a global network of networks
- Uses a combination of two protocols to communicate
 - Transmission Control Protocol
 - Internet Protocol



Your network is the part of the internet that you own.

— Dan Houser



TCP/IP

- The protocol of the internet!
- The protocols in the TCP/IP suite work together to:
 - Break the data into small pieces that can be efficiently handled by the network
 - Communicate the destination of the data to the network
 - Verify the receipt of the data on the other end of the transmission
 - Reconstruct the data in its original form



TCP/IP Protocol Suite (1)

- Internet Protocol (IP)
 - Specifies the format of packet (aka datagram) and the addressing scheme
- Transmission Control Protocol (TCP)
 - Enables two computers to establish a connection and exchange streams of data, guarantees delivery of data, and also guarantees that packets will be delivered in the same order in which they were sent
- User Datagram Protocol (UDP)
 - Provides a direct way to send and receive datagrams over an IP network with very few error recovery services; used primarily for broadcasting messages over a network
- Internet Control Message Protocol (ICMP)
 - Supports packets containing error, control, and informational messages; PING uses ICMP to test an internet connection
- Domain Name System (DNS)
 - Translates domain names into IP addresses
(phoenix.gov → 148.167.202.229)



TCP/IP Protocol Suite (2)

- Point-to-Point Protocol (PPP)
 - Sends packets to a server to connect a computer to the internet
- Address Resolution Protocol (ARP)
 - Converts an IP address into a physical address, such as an Ethernet address
 - A host wishing to obtain a physical address broadcasts an ARP request onto the TCP/IP network; the host on the network that has the IP address in the request then replies with its physical hardware address
- Reverse Address Resolution Protocol (RARP)
 - Allows a computer discover its IP address; in this case, the host broadcasts its physical address and an RARP server replies with the host's IP address
- Simple Network Management Protocol (SNMP)
 - Contains a set of protocols for managing complex networks



Quiz

- Poisoning the Domain Name Server may result in:
 - A user's IP address being deleted
 - A user unable to reach an organization via its IP address
 - A user being routed to the wrong organization's server
 - A user being denied access to a remote server



Quiz

- Poisoning the Domain Name Server may result in:
 - A user's IP address being deleted
 - A user unable to reach an organization via its IP address
 - A user being routed to the wrong organization's server
 - A user being denied access to a remote server



Ports

- TCP and other protocols uses a concept of numbered ports to manage connections and distinguish connections from one another
- The use of numbered ports also allows the computer to decide which particular software should handle a specific request or piece of data
 - It expects certain types of traffic on certain ports
- The Internet Assigned Names Authority (IANA) assigns port numbers



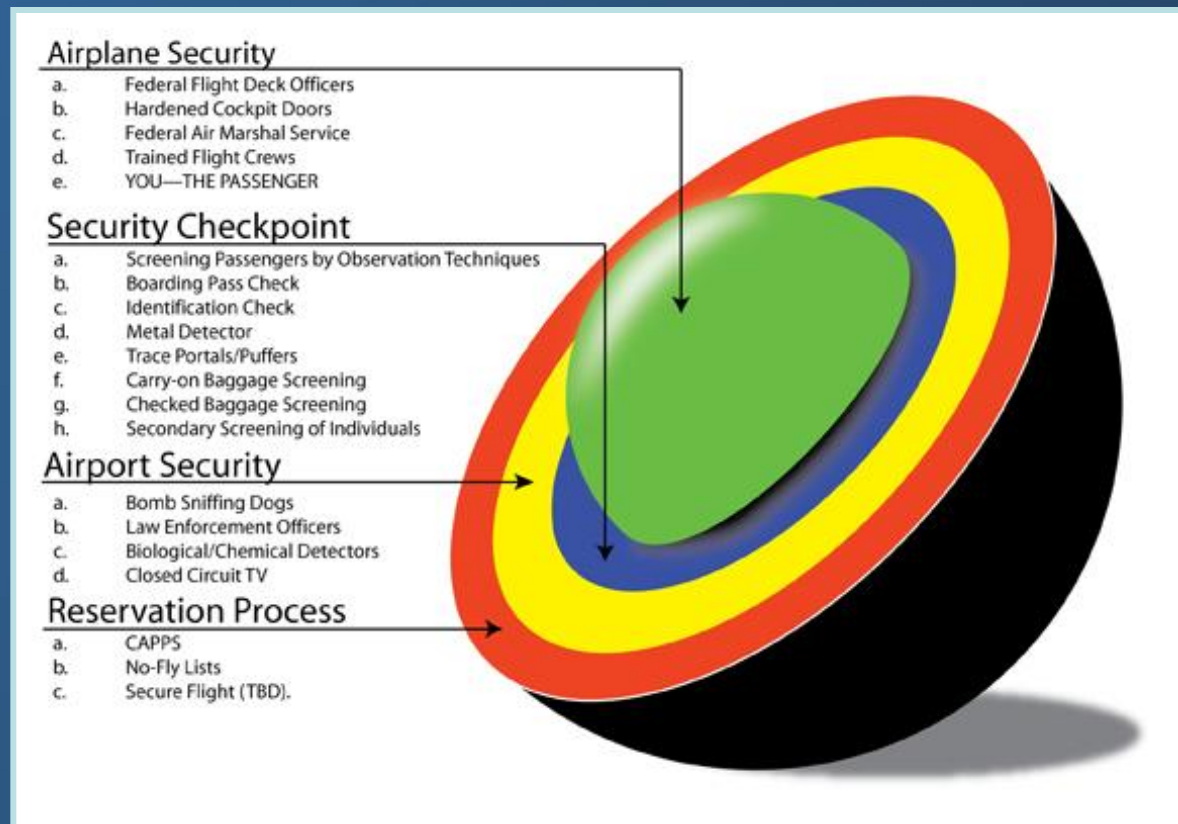
Standard Ports

- 20 and 21 - FTP (file transfer)
- 22 - SSH (secure shell remote access)
- 23 - Telnet (insecure remote access)
- 25 - SMTP (send e-mail)
- 53 - DNS (resolves a computer's name to an IP address)
- 80 - HTTP (normal Web browsing; also sometimes used for a proxy)
- 110 - POP3 (receive e-mail)
- 143 - IMAP (send/receive e-mail)
- 443 - HTTPS (secure Web connections)



Layered Security Concept

- Layered security – using multiple layers of different safeguards to provide stronger security



OSI 7-Layer Model

- A networking framework for implementing protocols in seven layers
- Each layer has a specific function to make sure your information is packaged correctly for transmission
 - Once your information reaches its destination, it travels back up the seven layers to get “unwrapped”
- Each layer has its own protocols, standards, devices, and security features

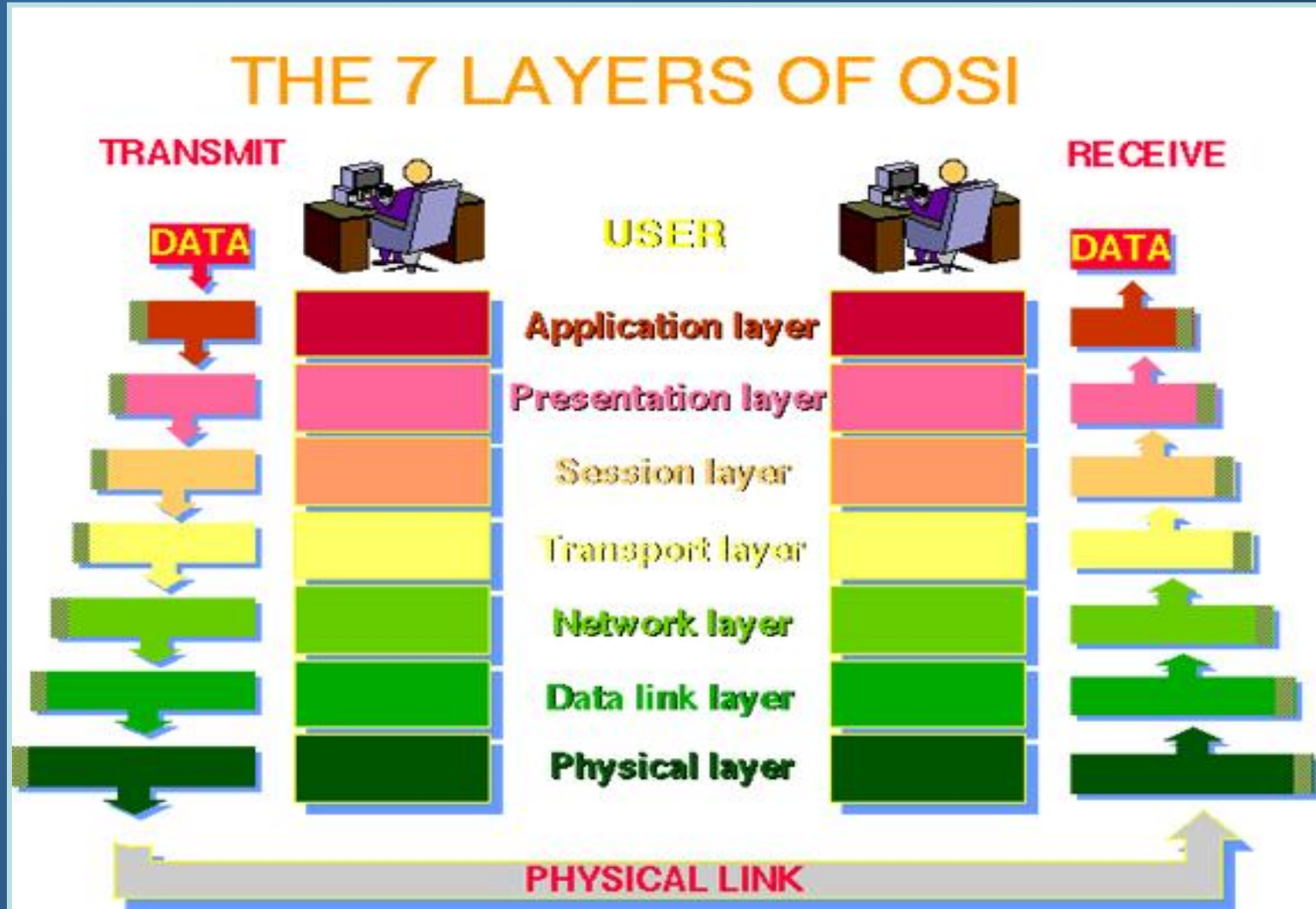


Quiz

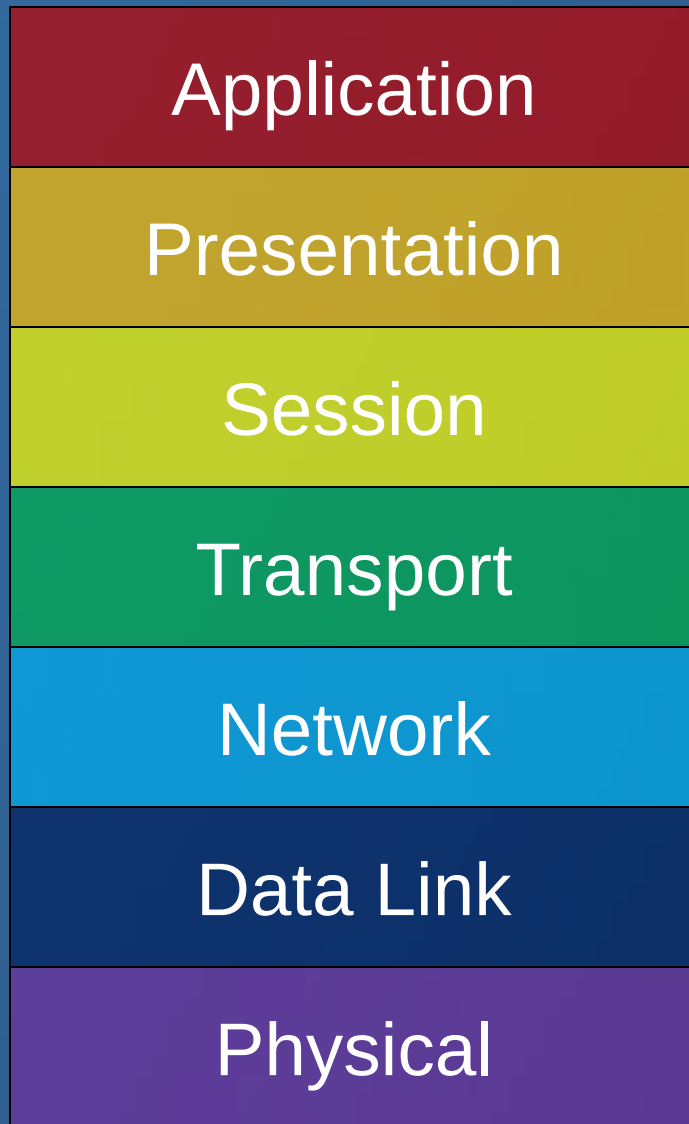
- Can you name the 7 layers of the OSI model?
- Hint: Please do not throw sausage pizza away



Please Do Not Throw Sausage Pizza Away



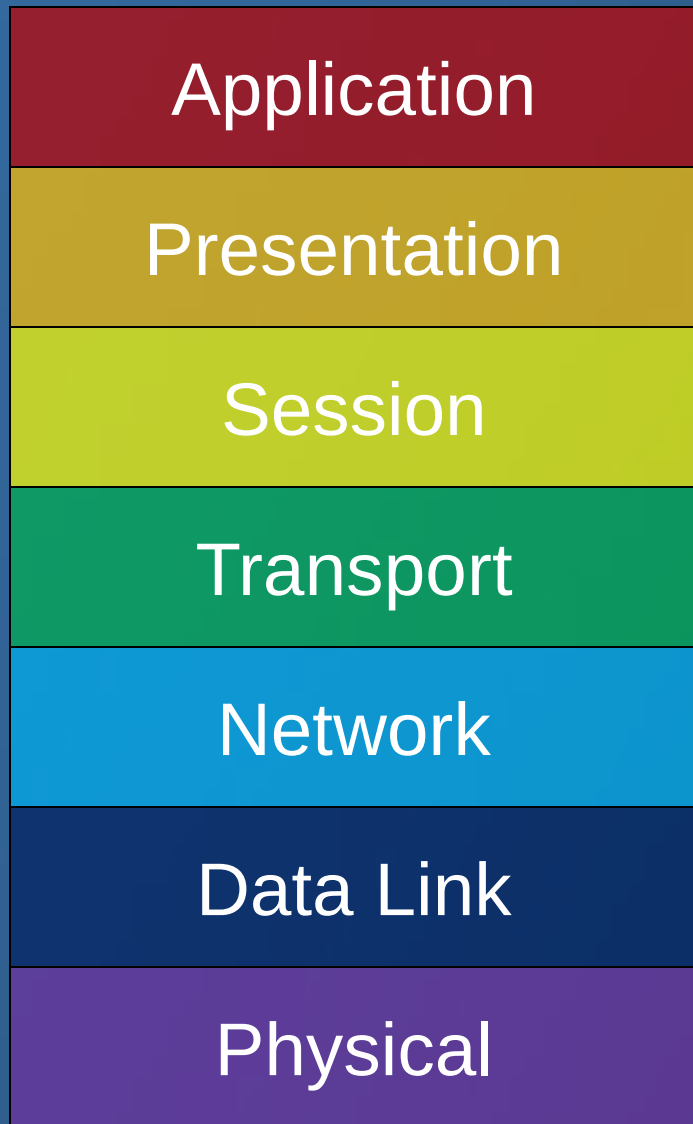
1 – Physical Layer



- Function
 - Transmits bit stream — electrical impulse, light or radio signal — through the network at the electrical and mechanical level on physical medium (cable)
- Devices
 - Repeaters to amplify signals
- Protocols and Standards
 - RS232, SONET, HSSI, X.21
- Security that can be Implemented
 - Confidentiality
 - Physical security safeguards to make sure nobody cuts or taps into cables



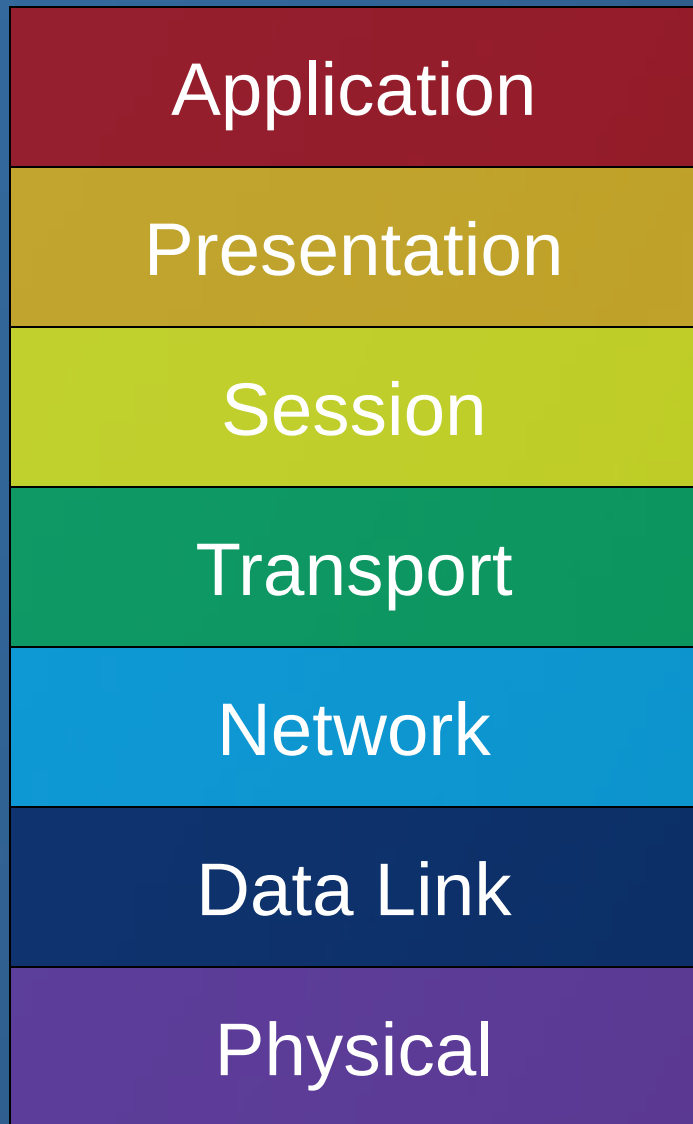
2 – Data Link Layer



- Function
 - Handles physical addressing, encodes data packets into bits (0s and 1s), and decodes them
- Devices
 - Bridges to connect different LAN segments and switches to determine where to send packets
- Protocols and Standards
 - SLIP, PPP, RARP, L2F, L2TP, ISDN, ARP
- Security that can be Implemented
 - Confidentiality
 - “Tunneling” to create a secure virtual private network (VPN) across the public Internet



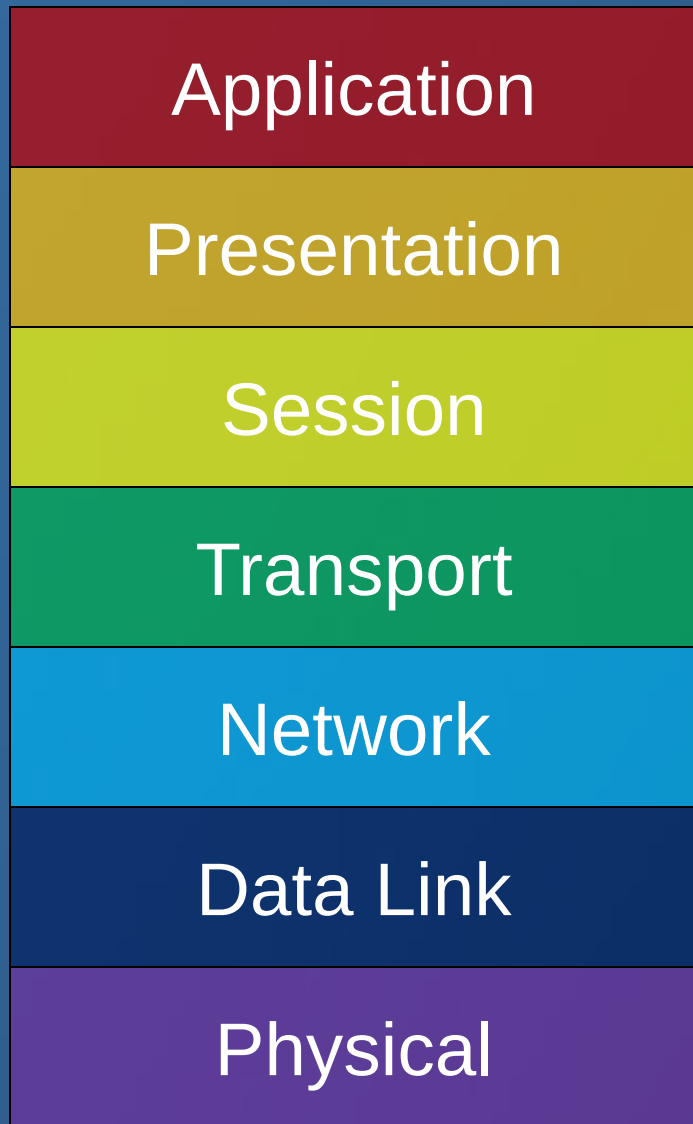
3 – Network Layer



- Function
 - Determines the best way to transfer data and which path or route data will take
- Devices
 - Routers to determine where to route traffic
- Protocols and Standards
 - IP, ICMP
- Security that can be Implemented
 - Confidentiality, authentication, data integrity
 - Firewalls and IPSec to encrypt and authenticate IP data



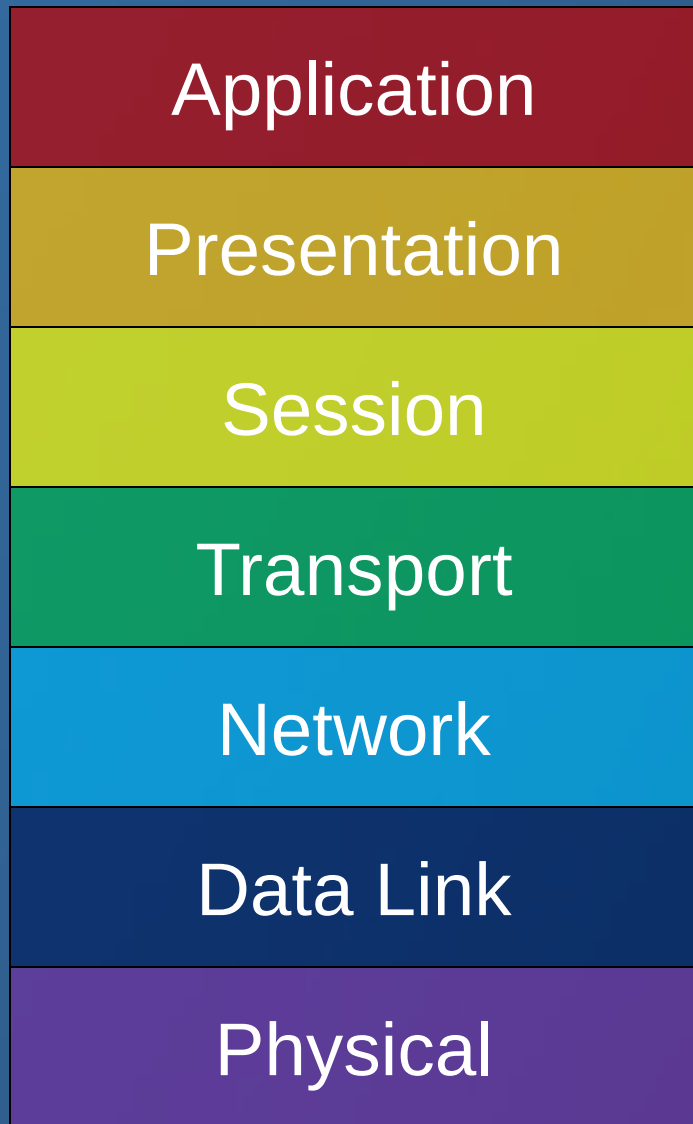
4 – Transport Layer



- Function
 - Provides end-to-end transmission integrity and ensures complete data transfer
- Devices
- Protocols and Standards
 - TCP, UDP, IPX, SSL (secure sockets layer)
- Security that can be Implemented
 - Confidentiality, authentication, integrity
 - Packet filtering firewalls to control network traffic and SSL to protect integrity and confidentiality



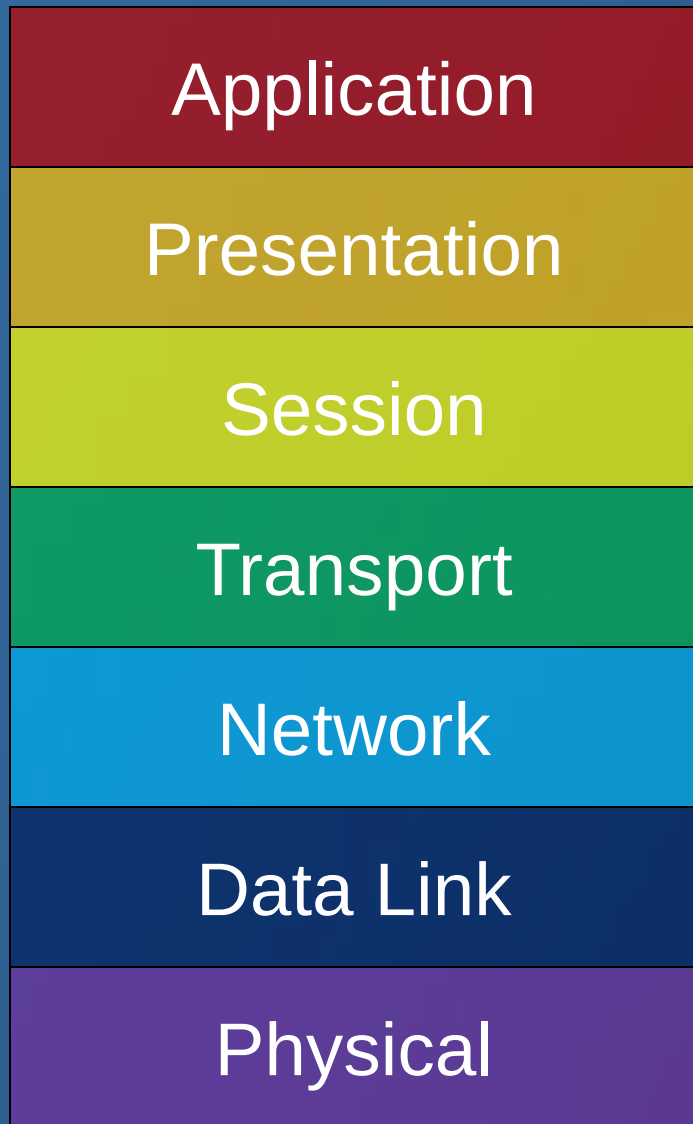
5 – Session Layer



- Function
 - Establishes a connection to another computer, maintains it during data transfer and releases it when done
- Devices
- Protocols and Standards
 - NFS, RPC, AppleTalk
- Security that can be Implemented



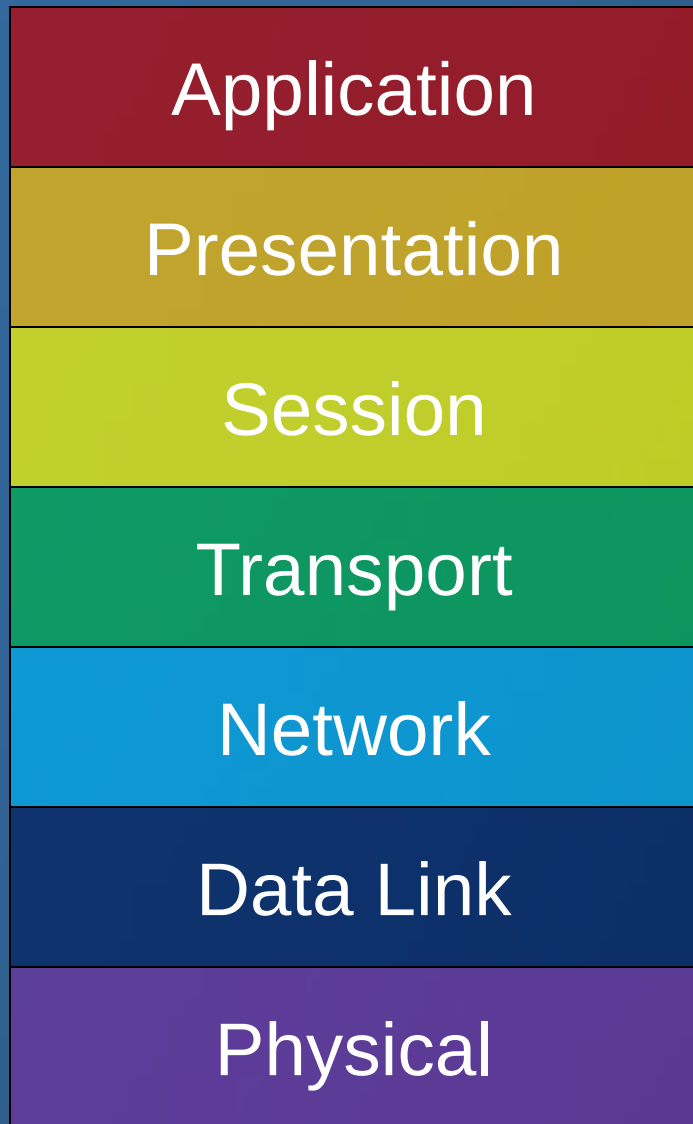
6 – Presentation Layer



- Function
 - Puts data into a format that all computers using the OSI model can understand
- Devices
- Protocols and Standards
 - ASCII, JPEG, GIF, MPEG, MIDI
- Security that can be Implemented
 - Confidentiality and authentication
 - Encryption



7 – Application Layer



- Function
 - Doesn't handle applications, but provides specific services for them such as file transfer
- Devices
 - Gateways to connect different types of networks (like Ethernet and fiber)
- Protocols and Standards
 - SMTP, HTTP, LPD, FTP, WWW, Telnet
- Security that can be Implemented
 - Confidentiality, authentication, data integrity, non-repudiation
 - Example: user authentication and privacy, such as S/MIME, a secure method of sending email



New Layers

- Layer 8 – Human
- Layer 9 – Politics



Quiz

- Which of the following defines a denial of service attack?
 - An action that prevents a system from functioning in accordance with its intended purpose
 - An action that allows unauthorized users to access some of the computing services available
 - An action that allows a hacker to compromise system information
 - An action that allows authorized users to access some of the computing services available



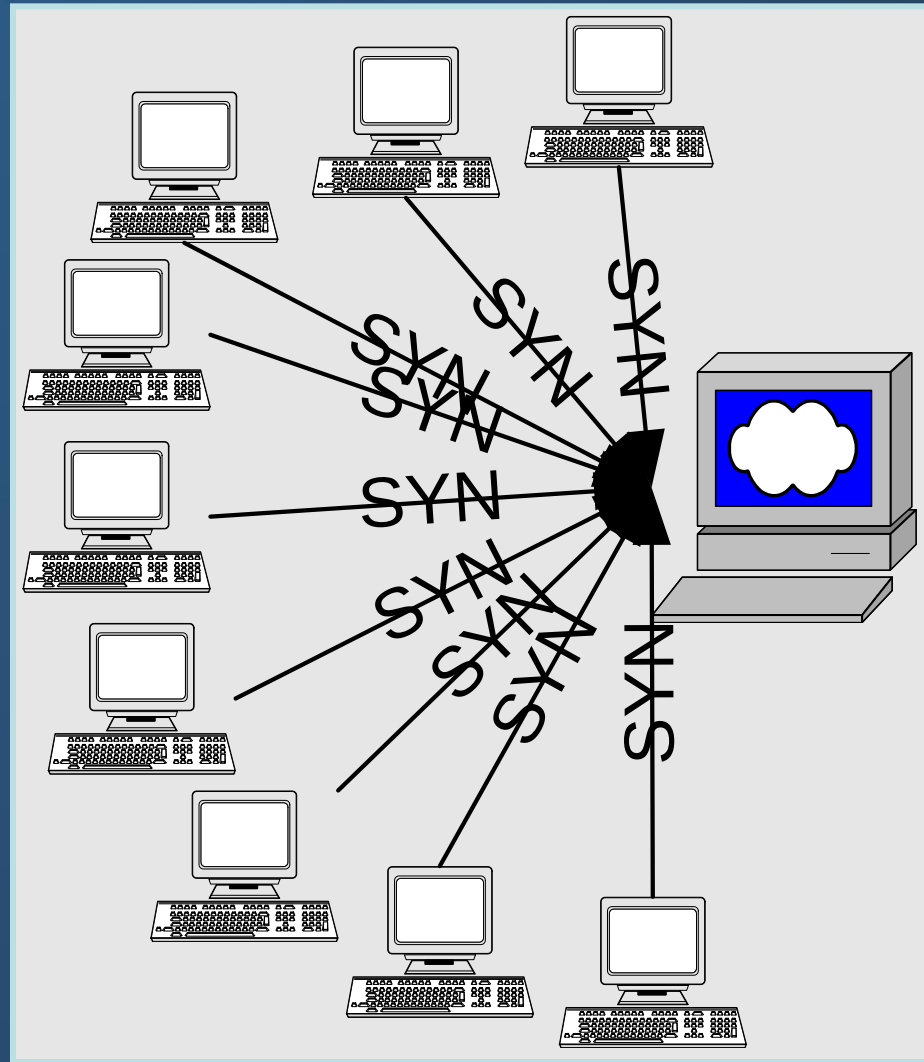
Quiz

- Which of the following defines a denial of service attack?
 - An action that prevents a system from functioning in accordance with its intended purpose
 - An action that allows unauthorized users to access some of the computing services available
 - An action that allows a hacker to compromise system information
 - An action that allows authorized users to access some of the computing services available

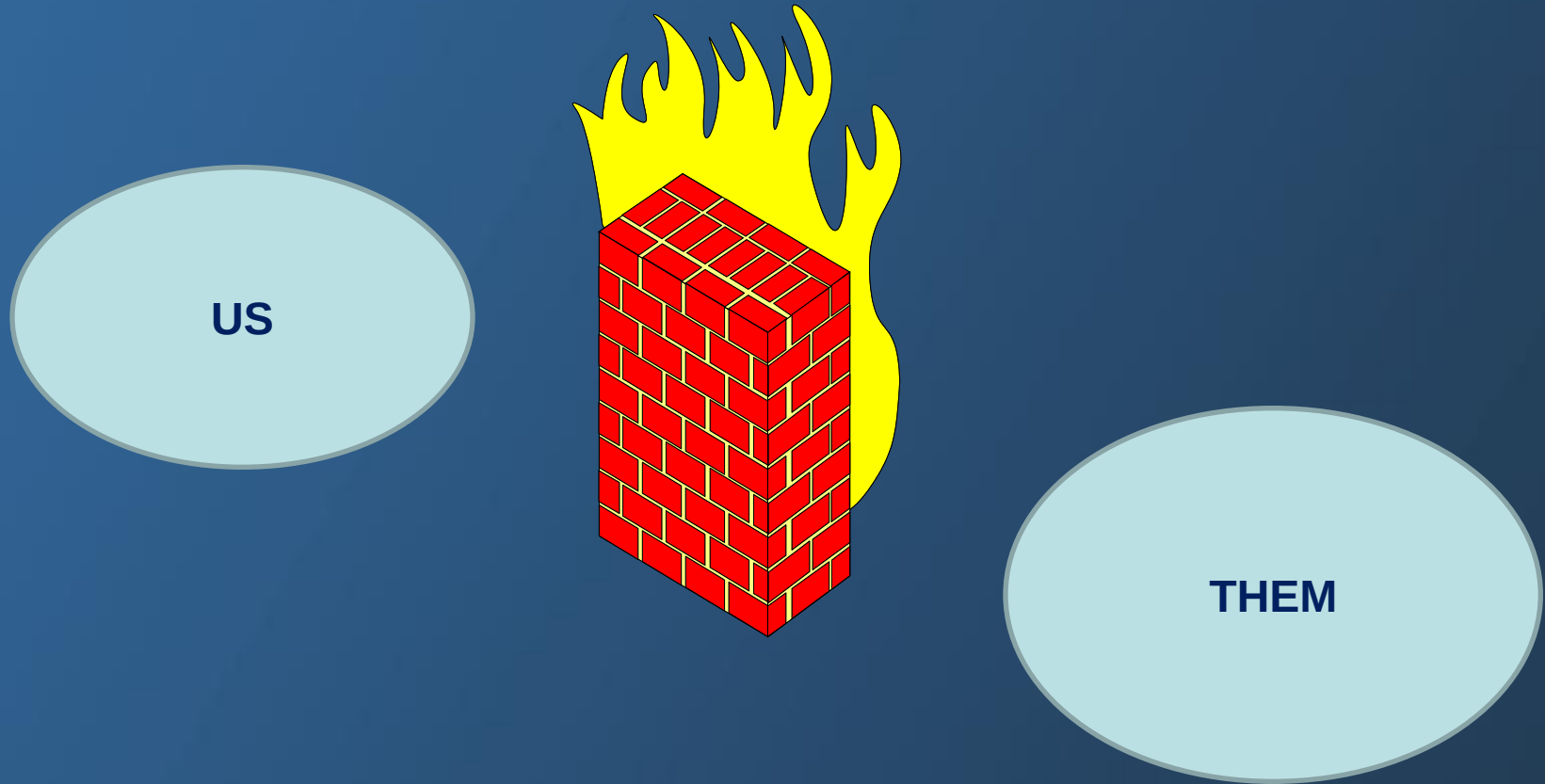


Network Threats

- Unauthorized access
- Unauthorized use for non-business purposes
- Eavesdropping
- Denial of service or other service interruptions
 - Example: SYN Flood
 - Distributed DoS
- Network Intrusion
- Probing
 - “What’s accessible?”
 - Example tool: NMAP network mapping tool

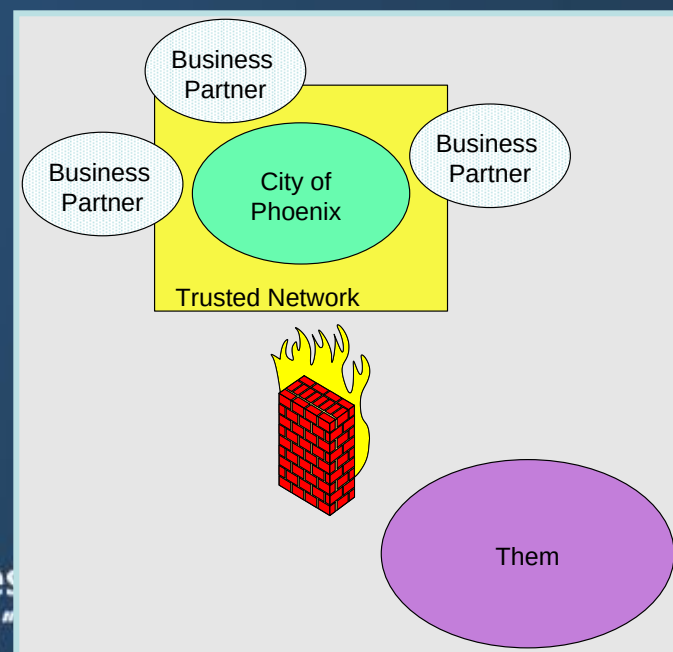


Network Safeguards



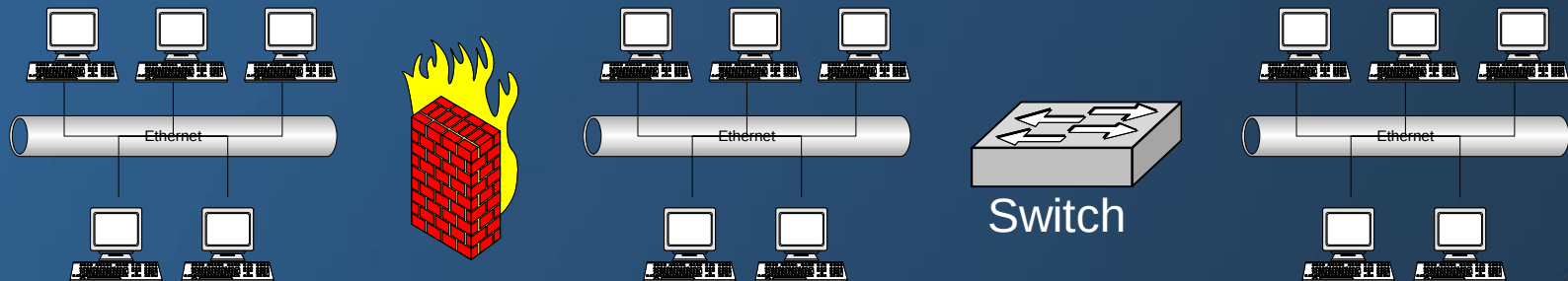
Perimeter Security

- Network segmentation
 - Isolate networks
- Protocol and address filtering
 - Only allow network traffic from specific protocols and/or addresses
- Network address translation
 - “Hide” your internal IP addresses
- Data inspection
 - Determine what data is trying to get in



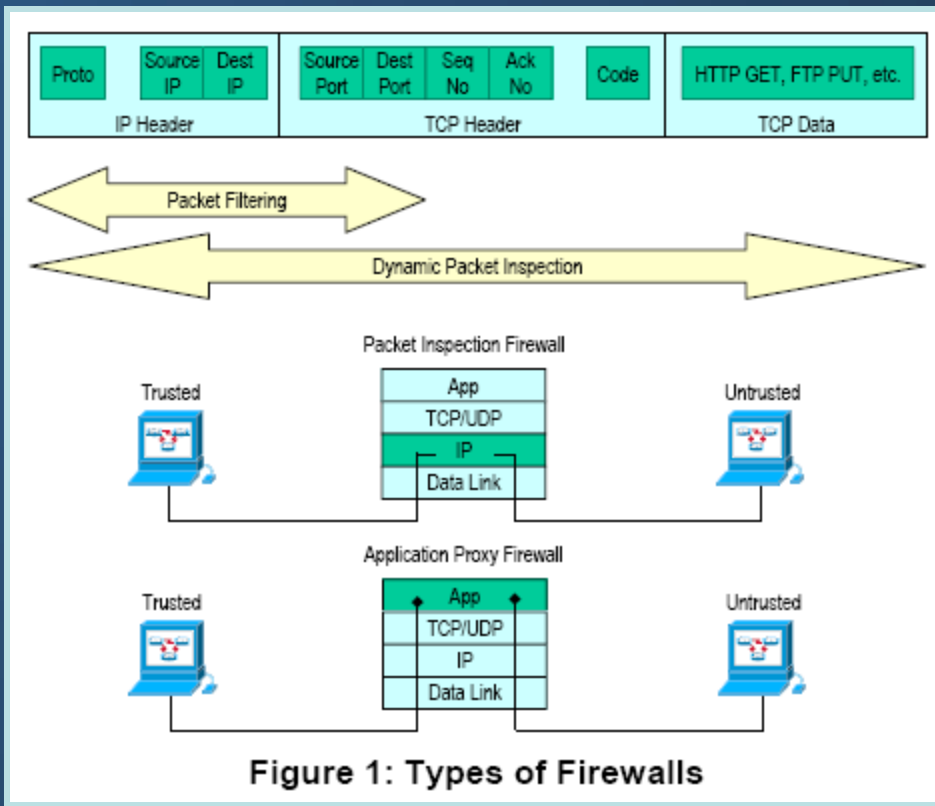
Segmentation

- Enforces security rules between two or more networks
 - Firewall provides physical segmentation
 - Virtual LAN (VLAN) provides logical segmentation
 - Implemented at switch



Firewalls

- Evaluates each network packet against a network security policy
 - Packet filtering firewalls
 - Stateful inspection firewalls
 - Proxy firewalls
 - Circuit-level
 - Application level
 - Personal firewalls for PCs



DMZs

- Protect internal networks using a DMZ (Perimeter Zone)
 - nt 1.2, Network Security Zones
- Internet services should be put into the DMZ, such as web, mail, FTP, VOIP

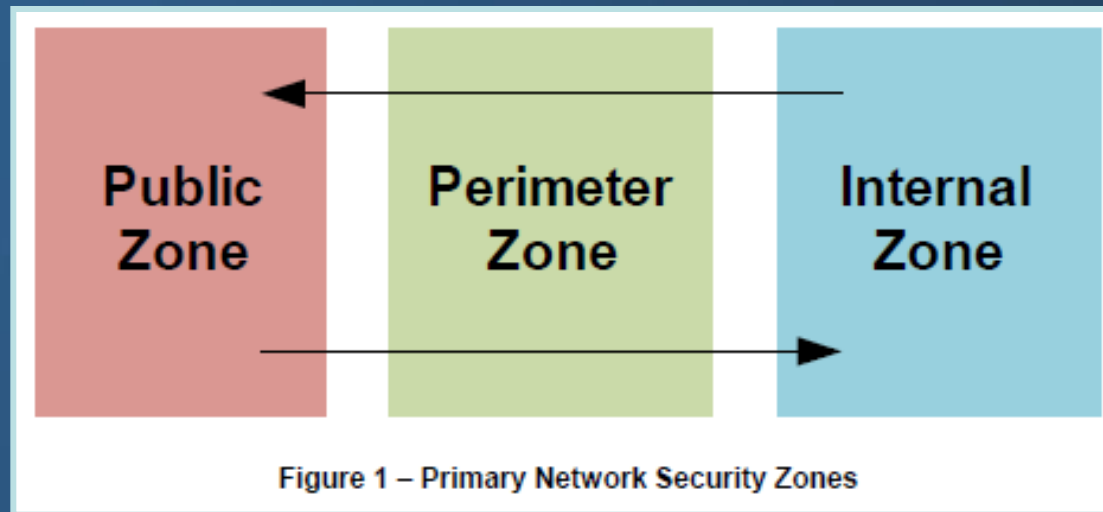


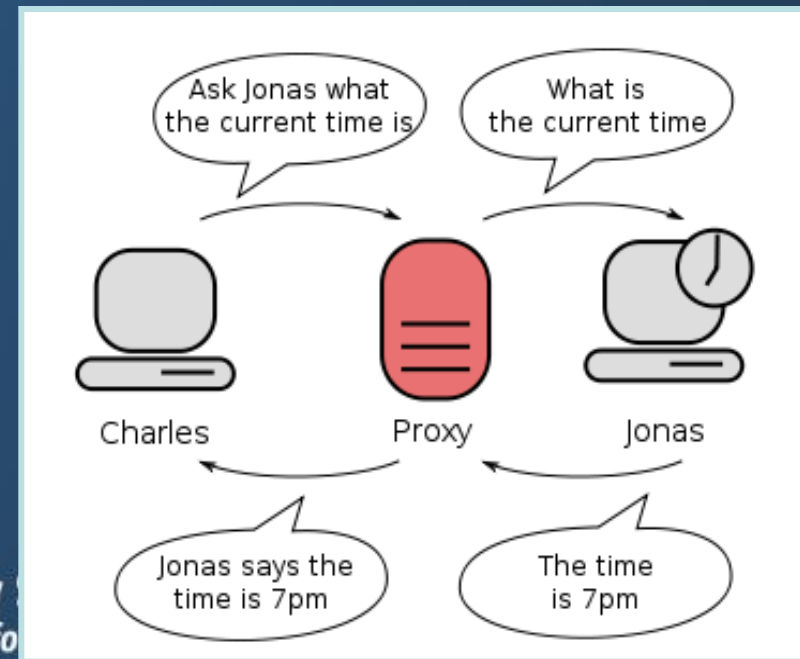
Figure 1 – Primary Network Security Zones

"Connecting Phoenix to Information"



Proxies

- A proxy server acts as an intermediary for requests from clients seeking resources from other servers
- Used to
 - Keep machines behind it anonymous, mainly for security
 - Speed up access to resources (caching web pages from a web server)
 - Apply access policy to network services or content (site blocking)
 - Bypass security / parental controls
 - Scan inbound and/or outbound content for malware or data loss prevention



Network IDS/IPS

- Network intrusion detection / prevention systems
- Appliances that monitor networks for malicious activity
 - Analyzes protocol activity
 - Examines network traffic for unusual traffic flows
- IDS identifies, logs, and alerts on malicious activity
- IPS also attempts to stop/block by dropping malicious packets, resetting the connection, and/or blocking traffic from the offending IP address



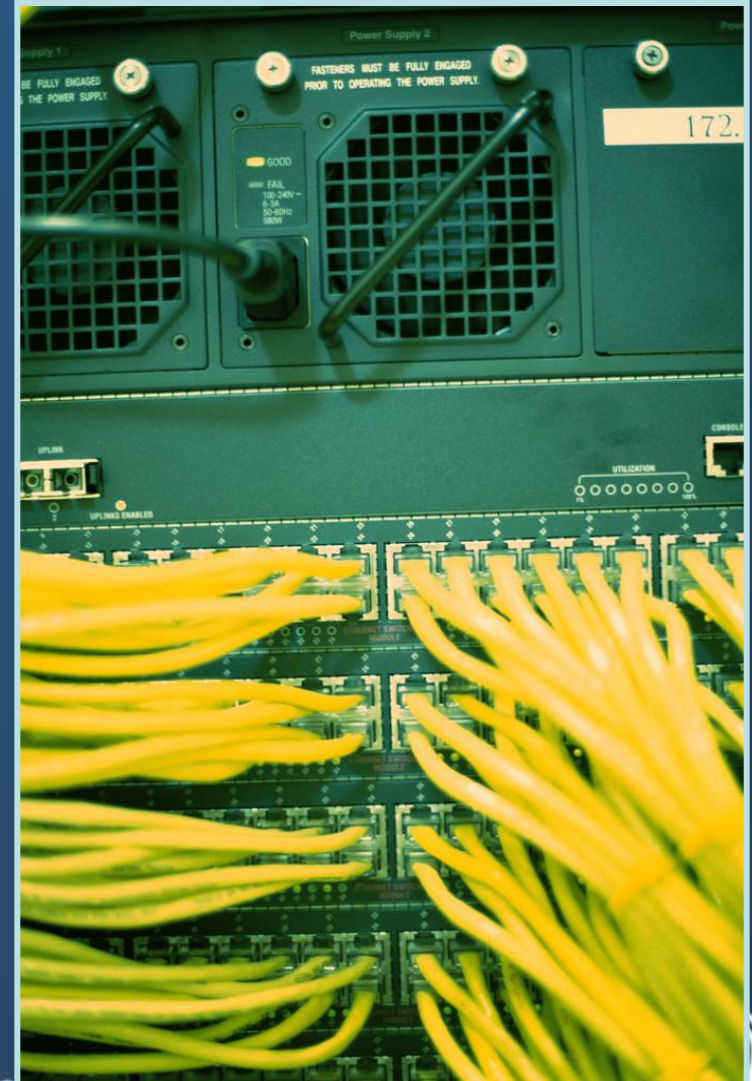
SANS Top 20 Controls

20 Critical Security Controls - Version 3.1

- Critical Control 1: Inventory of Authorized and Unauthorized Devices
- Critical Control 2: Inventory of Authorized and Unauthorized Software
- Critical Control 3: Secure Configurations for Hardware and Software on Laptops, Workstations, and Servers
- Critical Control 4: Continuous Vulnerability Assessment and Remediation
- Critical Control 5: Malware Defenses
- Critical Control 6: Application Software Security
- Critical Control 7: Wireless Device Control
- Critical Control 8: Data Recovery Capability
- Critical Control 9: Security Skills Assessment and Appropriate Training to Fill Gaps
-  Critical Control 10: Secure Configurations for Network Devices such as Firewalls, Routers, and Switches
-  Critical Control 11: Limitation and Control of Network Ports, Protocols, and Services
- Critical Control 12: Controlled Use of Administrative Privileges
-  Critical Control 13: Boundary Defense
- Critical Control 14: Maintenance, Monitoring, and Analysis of Security Audit Logs
- Critical Control 15: Controlled Access Based on the Need to Know
- Critical Control 16: Account Monitoring and Control
- Critical Control 17: Data Loss Prevention
- Critical Control 18: Incident Response Capability
-  Critical Control 19: Secure Network Engineering
- Critical Control 20: Penetration Tests and Red Team Exercises

Remote Access Security Protocols

- Password Authentication Protocol (PAP)
 - Provides standard authentication method, but password and username sent in the clear
- Challenge Handshake Authentication Protocol (CHAP)
 - Provides a type of authentication in which the authentication agent (typically a network server) sends the client program a random value that is used only once and an ID value (both the sender and peer share a predefined secret)
- Remote Authentication Dial-In User Service (RADIUS)
 - Provides a central database, which maintains user lists, passwords, and user profiles that can be accessed by remote access equipment on the network



Transmission Security Protocols

- Transport Layer Security Protocol (TLS)
 - Guarantees privacy and data integrity between client/server applications communicating over the internet
- Secure Shell (SSH)
 - Lets you log into another computer over a network, execute commands in a remote machine, and move files from one machine to another
 - Provides strong authentication and secure communications over insecure channels (host and user authentication, data compression, data confidentiality and integrity)
- Secure Sockets Layer (SSL)
 - Creates a secure connection between a client and a server, over which any amount of data can be sent securely (https)
- IP Security (IPSec)
 - Supports secure exchange of packets at the IP layer via a set of protocols
 - Used widely to implement Virtual Private Networks (VPNs)
 - Supports two encryption modes: Transport and Tunnel
 - Transport mode encrypts only the data portion (payload) of each packet, but leaves the header untouched
 - The more secure Tunnel mode encrypts both the header and the payload
 - On the receiving side, an IPSec-compliant device decrypts each packet



Quiz

- Why are local area networks more vulnerable to data compromise than mainframe computers?
 - Transmission capacity
 - Storage capacity
 - Multiple points of access
 - Removable media



Quiz

- Why are local area networks more vulnerable to data compromise than mainframe computers?
 - Transmission capacity
 - Storage capacity
 - Multiple points of access
 - Removable media



Thanks!



Questions?
Contact ispo@phoenix.gov

Information Technology Services
"Connecting Phoenix to Information"

